

2. Web Enumeration (Gobuster/Feroxbuster)

Dalam Boot2Root, sekitar 70% soal biasanya berawal dari web.

Banyak peserta melihat website seperti:

Welcome to My Website

lalu bingung.

Padahal halaman utama sering hanya "umpan". Flag atau celah biasanya ada di direktori tersembunyi.

Tujuan Web Enumeration

Mencari:

Direktori tersembunyi

File tersembunyi

Panel admin

Backup file

Upload page

Login page

API endpoint

Source code bocor

Langkah 1: Buka Website

Misal hasil Nmap:

80/tcp open http

Buka:

http://192.168.56.101

Perhatikan:

Judul halaman

Copyright

Versi CMS

Form login

Upload file

Langkah 2: Lihat Source Code

Tekan:

CTRL + U

atau

curl http://IP

Cari:

<!-- TODO remove admin page -->

atau

<!-- /secret -->

atau

var api="/admin/api";

Sering kali petunjuk ada di komentar.

Langkah 3: Cek robots.txt

Akses:

http://IP/robots.txt

Contoh:

Disallow: /admin

Disallow: /backup

Langsung buka.

Langkah 4: Directory Brute Force

Inilah teknik yang paling sering dipakai.

Gobuster

```
gobuster dir \  
-u http://IP \  
-w /usr/share/wordlists/dirb/common.txt
```

Contoh hasil:

/admin
/uploads
/backup
/test

Feroxbuster

Lebih modern.

feroxbuster -u http://IP

Contoh:

/login
/api
/admin
/uploads

Langkah 5: Cari File Menarik

Sering ditemukan:

backup.zip
backup.tar.gz
db.sql
config.php.bak

Contoh:

http://IP/backup.zip

Download:

wget http://IP/backup.zip

Langkah 6: Enumerasi Login

Misal ditemukan:

/admin

Perhatikan:

username default

password default

hint pada source code

Contoh source:

```
<!-- admin:admin123 -->
```

Kadang sesederhana itu.

Langkah 7: Identifikasi Teknologi

Gunakan:

whatweb http://IP

Contoh:

Apache
PHP
WordPress

atau

Laravel

atau

Django

Ini membantu memahami struktur aplikasi.

Langkah 8: Cari Parameter

Misal URL:

http://IP/view.php?id=1

Parameter:

id=1

Ini menarik karena bisa mengarah ke:

SQL Injection

IDOR

LFI

Contoh lain:

?page=home

Bisa mengarah ke LFI.

Langkah 9: Enumerasi Upload

Misal ada:

/upload.php

Pertanyaan:

File apa yang boleh diupload?

Ada validasi?

Disimpan di mana?

Ini sering menjadi jalan menuju shell pada lab CTF.

Langkah 10: Enumerasi API

Kadang ditemukan:

/api

atau

/api/v1

Gunakan:

curl http://IP/api

atau

curl -X OPTIONS http://IP/api

Cari endpoint yang tidak terdokumentasi.

Checklist Saat Menemukan Website

Selalu cek:

/

robots.txt

sitemap.xml

/admin

/login

/uploads

/backup

/api

Wordlist yang Sering Dipakai

Kali Linux:

`/usr/share/wordlists/dirb/common.txt`

`/usr/share/seclists/`

SecLists adalah wordlist yang hampir selalu dipakai dalam CTF dan Boot2Root.

Studi Kasus LKS

Nmap:

`80/tcp open http`

Website:

Welcome

Tidak ada apa-apa.

Jalankan:

```
gobuster dir \  
-u http://IP \  
-w common.txt
```

Hasil:

`/backup`

Buka:

`/backup`

Isi:

`database.sql`

Dalam database:

`admin:password123`

Login berhasil.

Flag ditemukan.

Mindset Penting

Jangan langsung mencari exploit.

Urutan yang benar:

1. Nmap
2. Enumerasi Web
3. Cari informasi
4. Cari kredensial
5. Cari misconfiguration
6. Baru pikirkan exploit

Karena sebagian besar mesin Boot2Root mudah diselesaikan hanya dengan enumerasi yang teliti.

Materi berikutnya yang sangat sering muncul setelah Web Enumeration adalah FTP Enumeration, yaitu cara menganalisis FTP, anonymous login, backup file, dan kredensial bocor dalam konteks CTF/lab.